



Atelier 3 : Cartographie Fonctionnelle & Analyse des Risques

Cartographie Fonctionnelle (Mindmap / Arborescence)

Le système se découpe en 4 grands blocs liés aux profils utilisateurs :

1. Espace Public & Visiteur (Front-end SPA React)

- **Navigation & Recherche** : Consultation du catalogue général des événements.
- **Moteur de recherche** : Filtrage multicritères par date, par ville et par catégorie d'événement (concert, conférence, atelier).

2. Espace Client (Compte sécurisé)

- **Authentification** : Inscription, connexion et gestion du profil via un protocole sécurisé (OAuth2 / JWT).
- **Tunnel de réservation (Flux Principal)** :
 1. Sélection d'un événement et d'une catégorie tarifaire.
 2. Sélection de la quantité de places (1 à N).
 3. Activation du panier temporaire (Verrouillage du stock pendant 10 minutes).
 4. Application et validation d'un code promo.
 5. Formulaire de paiement.
 6. Page de confirmation et génération des billets.
- **Gestion des billets** : Consultation de l'historique, téléchargement des billets, demande d'annulation et de remboursement.

3. Espace Organisateur

- **Gestion des événements** : Création, modification et publication d'un événement.
- **Configuration de la billetterie** : Définition de la capacité globale (jauge), des catégories de billets, des quotas associés et des grilles tarifaires (Plein tarif, Réduit, Early-bird).
- **Suivi** : Tableau de bord de l'évolution des ventes et du taux de remplissage.

4. Back-Office Administrateur

- **Supervision globale** : Gestion des comptes utilisateurs (bloquer/débloquer).
- **Gestion commerciale** : Création et paramétrage des codes promotionnels (définition de la date d'expiration et du nombre maximal d'utilisations).
- **Modération financière** : Traitement et validation des demandes de remboursement.



Identification et Matrice des Risques

Pour chaque zone critique, nous évaluons le **Risque Produit** selon la formule standard :

Criticité = Probabilité d'occurrence x Impact Métier / Financier (noté de 1 à 3).

Zone 1 : Le tunnel de réservation & Gestion des quotas (Le Cœur du Métier)

- **Scénario d'échec** : Deux utilisateurs achètent simultanément la dernière place disponible (Sur-réservation / Race Condition).
- **Règle métier associée** : RM1 (Le nombre de places vendues ne peut jamais dépasser la capacité).
- **Analyse du risque** :
 - *Probabilité* : 3 (Très élevée lors des ouvertures de billetterie / "Flash Sales").
 - *Impact* : 3 (Critique : clients mécontents à l'entrée de la salle, impact légal et réputationnel).
 - **Criticité** : 9/9 (Priorité absolue de test - Test technique/Charge à prévoir).

Zone 2 : Le panier temporaire (Gestion du Temps)

- **Scénario d'échec** : Un utilisateur réserve 6 places, ne paie pas, mais les places restent bloquées indéfiniment dans sa session, empêchant d'autres clients d'acheter (Rétention frauduleuse de stock).
- **Règle métier associée** : RM2 (Une réservation non payée expire après 10 minutes et libère le stock).
- **Analyse du risque** :
 - *Probabilité* : 2 (Moyenne : liée à des coupures réseau, des abandons de panier ou des bugs de synchronisation).
 - *Impact* : 2 (Modéré à Fort : manque à gagner financier pour l'organisateur si l'événement affiche complet à tort).
 - **Criticité** : 4/9 (Priorité Haute - Scénarios de tests temporels et "Flaky" à surveiller).

Zone 3 : La passerelle de paiement & calculs financiers

- **Scénario d'échec** : Le système applique une réduction, mais transmet un montant erroné ou arrondi à la passerelle de paiement (Écart de paiement).
- **Règle métier associée** : Cohérence financière Orders $\rightarrow$ Payments.
- **Analyse du risque** :
 - *Probabilité* : 1 (Faible : généralement encadré par des types de données stricts comme l'indique l'architecture en cents `price_cents`).
 - *Impact* : 3 (Critique : comptabilité faussée, litiges bancaires immédiats).
 - **Criticité** : 3/9 (Priorité Moyenne à Haute - Nécessite des requêtes de réconciliation SQL).

Zone 4 : Sécurité des données (Accès aux billets)

- **Scénario d'échec** : Un client connecté modifie l'identifiant de la commande dans l'URL (ex: change `order_id=101` en `order_id=102`) et accède au billet d'un autre utilisateur.



- **Règle métier associée** : RM7 (Un client ne peut consulter que ses propres billets).
- **Analyse du risque** :
 - *Probabilité* : 2 (Moyenne : faille de contrôle d'accès très courante de type IDOR).
 - *Impact* : 3 (Critique : fuite de données personnelles, vol de billets par simple copie d'écran).
 - **Criticité** : 6/9 (**Priorité Haute - Focus majeur pour les tests d'API et la sécurité OWASP**).